SUP'COM

ANNEXES DE SÉCURITÉ

Projet ExamGuard

Compléments au recueil des besoins, version 2.0

Encadrant : Mohamed-Bécha Kaâniche

Équipe projet :

— Laith GRITLI
— Ahmed ABDELHEDI
— Mohamed Yassine AMRI

Contenu : algorithmes de marquage détaillés, décomposition du modèle de menaces, plan de tests, fiches des cas d'utilisation de sécurité, correspondance avec la version 1.0.

Version : 2.0 – 12 novembre 2026

Année universitaire 2026–2027

Table des matières

A Spécification détaillée des mécanismes de dissimulation **1**
A.1 *Fingerprinting* par décalage inter-mots 1
A.2 *Watermarking* robuste du bandeau d'en-tête 3
A.3 Stéganographie : manifeste dissimulé dans le sceau 4
A.4 Banc d'évaluation 5
A.5 Preuve détachée et limites de l'attribution 5

B Modèle de menaces : décomposition **8**
B.1 Informations sur le modèle 8
B.2 Décomposition : dépendances externes 8
B.3 Décomposition : points d'entrée 9
B.4 Décomposition : actifs et niveaux de confiance 9
B.5 Décomposition : flux de données et frontières de confiance 10
B.6 Profil de sécurité 10
B.7 Grille OWASP Risk Rating reproductible 11
B.8 Second arbre d'attaque 13

C Plan de tests **14**
C.1 Tests fonctionnels 14
C.2 Tests d'abus 15
C.3 Essais de falsification et d'interopérabilité additionnels 16

D Fiches des cas d'utilisation de sécurité **17**

E Correspondance avec la version 1.0 **21**

Annexe A. Spécification détaillée des mécanismes de dissimulation

Cette annexe détaille les algorithmes résumés au chapitre 5 du recueil des besoins : étapes d'insertion et de détection, format des charges, banc d'évaluation. Les références [R6] et [R7] sont celles du recueil.

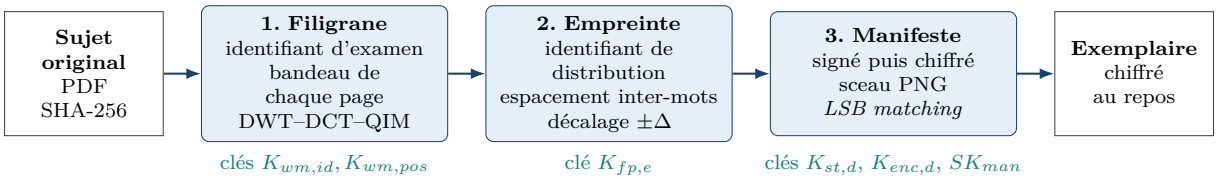


FIGURE A.1 – Chaîne de génération d'un exemplaire

A.1 *Fingerprinting* par décalage inter-mots

A.1.1 Principe

Le codage par décalage de mots [R6] déplace horizontalement certains mots d'une quantité trop faible pour être perçue. Le mécanisme vise à conserver le texte extractible et le nombre de pages : cette propriété n'est vérifiée que pour des PDF textuels admissibles. L'extraction des positions par PDFBox ne suffit pas à déplacer un mot : l'implémentation doit traiter les opérateurs de contenu PDF (notamment Tj/TJ, matrices de texte et fontes) ou régénérer la page à partir d'un modèle de mise en page contrôlé. Les écritures sont soumises à une comparaison bit-à-bit du texte extrait et à un contrôle visuel et de géométrie. Les PDF comportant écritures complexes, calques, texte tourné ou texte converti en dessin vectoriel sont refusés si le moteur ne peut les modifier sans perte.

A.1.2 Mot de code

- Clé d'examen : $K_{fp,e} = \mathrm{HKDF}(K_m, \texttt{"EG/fp/v1"} \,\|\, examId)$.
- Identifiant pseudonyme : ID_{fp}, formé des 48 premiers bits de HMAC-SHA-256$(K_{fp,e}, distributionId)$.
- Mot de code : $c = ID_{fp} \,\|\, \mathrm{CRC\text{-}16}(ID_{fp})$, soit 64 bits (CRC-16/CCITT, polynôme `0x1021`).

L'identifiant ne contient aucune donnée personnelle. La dérivation HMAC réduit la possibilité de fabriquer un identifiant nouveau sans connaître la clé, mais la copie de marqueurs existants et la collusion restent possibles. Le CRC-16 n'est **ni une signature, ni un MAC, ni un code anti-collusion** : il sert seulement à rejeter une partie des décodages accidentellement invalides. Avant toute attribution, le serveur compare le code

extrait à la liste des HMAC attendus pour les distributions de l'examen et cherche un second indice indépendant concordant (manifeste signé ou empreinte exacte du fichier).

A.1.3 Insertion

1. PDFBox extrait les lignes de texte et l'abscisse de chaque mot.
2. Sont *éligibles* les mots intérieurs (ni premier ni dernier) des lignes d'au moins 6 mots. Les marges ne sont donc jamais modifiées.
3. Un mot éligible sur deux est un *porteur* ; ses deux voisins, immobiles, servent de référence au décodage.
4. Pour coder le bit 1, le porteur est décalé de $+\Delta$ (vers la droite) ; pour le bit 0, de $-\Delta$. L'espace précédent varie de $\pm\Delta$ et l'espace suivant de $\mp\Delta$: la longueur de la ligne est inchangée.
5. Les positions porteuses sont numérotées *globalement* sur les pages dans l'ordre de lecture stable de l'original, de 0 à $N-1$. Sur la position j on inscrit le bit $c[j \bmod 64]$. **L'indice ne redémarre jamais à un changement de page**. Avec $N \geq 192$, chaque bit apparaît au moins trois fois dans l'exemplaire complet. Une page isolée n'est pas réputée identifiable individuellement, à moins de comporter à elle seule trois répétitions complètes du code.
6. Le moteur écrit la page au moyen d'opérateurs PDF de positionnement de texte contrôlés, sans changer les chaînes de glyphes et sans modifier les mots de référence. Il compare ensuite texte, nombre de pages, limites des lignes, positions et rendu avant de publier le fichier.

Paramètre	**Valeur**	**Commentaire**
Amplitude du décalage Δ	0,40 pt (0,14 mm)	Inférieure au seuil de perception rapporté par [R6] (1/150 de pouce).
Longueur du mot de code	64 bits	48 bits d'identifiant, 16 bits de contrôle.
Répétitions minimales r	3	Vote majoritaire par bit.
Porteurs requis	≥ 192 au total	Compter les positions réellement modifiables sur tout le PDF ; 384 mots éligibles n'est qu'un ordre de grandeur.

TABLE A.1 – Paramètres du *fingerprinting*

A.1.4 Détection

La détection est *informée* : le serveur conserve l'original.

1. L'examen est identifié par le filigrane ou, à défaut, par le condensé SHA-256 du texte extrait et normalisé, insensible au marquage.
2. Les lignes et les mots du fichier suspect sont appariés à ceux de l'original. Pour chaque ligne, l'échelle et la translation sont estimées par moindres carrés sur les mots de référence.
3. Pour chaque porteur, le signe de l'écart résiduel donne un bit.

4. Les bits sont regroupés selon l'indice global j mod 64 et décidés par vote majoritaire, avec un indicateur de confiance et un taux d'erreur.
5. Le CRC-16 élimine certains décodages aberrants ; il n'authentifie pas le code. Si le mot passe ce contrôle, le serveur le confronte aux HMAC recalculés de *toutes* les distributions autorisées de l'examen. Si plusieurs candidats, une discordance ou des indices de collusion apparaissent, il s'abstient. Une identification par marque seule n'est jamais assimilée à une preuve de l'auteur de la fuite.

A.2 *Watermarking* robuste du bandeau d'en-tête

A.2.1 Charge et support

— Clés distinctes : $K_{wm,id} = \mathrm{HKDF}(K_m, \texttt{"EG/wm-id/v1"})$ pour le HMAC et $K_{wm,pos} = \mathrm{HKDF}(K_m, \texttt{"EG/wm-pos/v1"})$ pour la permutation. Les paramètres publics de permutation et sa version sont fixes et documentés ; aucune clé ne sert à deux usages.

— Charge : $w = ID_{ex} \,\|\, \text{CRC-16}(ID_{ex})$, 48 bits, où ID_{ex} = 32 premiers bits de HMAC-SHA-256($K_{wm,id}$, *examId*).

— Support : bandeau institutionnel de 1600×192 pixels en niveaux de gris, placé en tête de chaque page, délimité par un filet servant de repère de recadrage et stocké sans perte dans le PDF.

A.2.2 Insertion

1. Transformée en ondelettes discrète de Haar à un niveau ; seule la sous-bande d'approximation LL (800×96) est modifiée.
2. Découpage de LL en 1 200 blocs de 8×8 ; DCT de chaque bloc.
3. Les blocs sont permutés selon un générateur reproductible à clé $K_{wm,pos}$, avec tirages uniformes sans biais modulo ; le bloc de rang i porte le bit i mod 48, soit 25 répétitions par bit.
4. Modulation d'index de quantification [R7] du coefficient de fréquence moyenne $(3, 2)$: pour un bit b, $c' = \Delta_q \cdot \mathrm{round}\Big((c - b\,\Delta_q/2)/\Delta_q\Big) + b\,\Delta_q/2$, avec $\Delta_q = 40$.
5. DCT inverse puis DWT inverse, arrondi et contrôle de saturation [0,255]. Les coefficients, le PSNR et la BER sont revérifiés après sérialisation réelle de l'image PDF.

A.2.3 Détection

La détection est *aveugle*. Le bandeau est extrait du PDF, ou recadré par l'auditeur dans une image, puis ramené à 1600×192. Les mêmes transformées sont appliquées ; chaque bloc donne le bit dont le quantificateur est le plus proche ; chaque bit de la charge est décidé par vote majoritaire sur ses 25 répétitions ; le CRC-16 valide le résultat, puis ID_{ex} est recherché dans la table des examens.

A.3 Stéganographie : manifeste dissimulé dans le sceau

A.3.1 Rôle

Le sceau est un canal de dissimulation pour un manifeste signé puis chiffré. La stéganographie est fragile et une partie du contenu peut être altérée sans que les bits du sceau changent. La validation de sa signature prouve uniquement l'authenticité et l'intégrité des champs du manifeste ; elle ne valide **ni l'intégrité octet à octet du PDF ni l'identité de la personne responsable d'une divulgation**. Pour vérifier le fichier complet intact, le système utilise l'enregistrement détaché signé défini à l'annexe A.5.

A.3.2 Charge

— Manifeste M (143 octets) : version (1), *examId* (16), *distributionId* (16), ID_{fp} (6), horodatage UTC (8), condensé SHA-256 de l'original (32), signature Ed25519 (SK_{man}) des champs précédents (64).

— Chiffrement : $C = \text{AES-256-GCM}(K_{enc,d}, \mathit{nonce}, M)$. La donnée associée comprend la version, `examId` et `distributionId` encodés sans ambiguïté.

— Clé de chiffrement *par distribution* :

$$K_{enc,d} = \text{HKDF}(K_m, ctx_{enc,d}),$$
$$ctx_{enc,d} = \text{Encode}(\texttt{"EG/st-aead/v1"}, \mathit{examId}, \mathit{distributionId}).$$

Les champs de contexte sont sérialisés avec leurs longueurs ; la clé est propre à la copie et distincte de celle du placement.

— Trame insérée : longueur (2 octets), *nonce* (12), C (143), étiquette (16), soit 173 octets ou 1 384 bits.

A.3.3 Insertion et extraction

1. Support : sceau PNG RVB de 256 × 256 pixels, soit 196 608 composantes ; le taux d'insertion est de 0,70 %.
2. Pour chaque distribution d, le moteur dérive une clé de parcours :

$$K_{st,d} = \text{HKDF}(K_m, ctx_{st,d}),$$
$$ctx_{st,d} = \text{Encode}(\texttt{"EG/st-pos/v1"}, \mathit{examId}, \mathit{distributionId}).$$

Les champs ont un encodage canonique et le domaine est distinct du chiffrement. Une permutation Fisher–Yates sur les 196 608 composantes est construite par tirages uniformes (*rejection sampling*) sur un flux ChaCha20 dédié au placement. Le nonce de 96 bits est fixe (zéro) et le compteur commence à 1 *uniquement parce que la clé est différente par distribution* ; aucun flux ni aucune clé n'est réutilisé à un autre usage.

3. Le détecteur identifie d'abord l'examen par le filigrane ou le texte normalisé, puis énumère uniquement ses distributions autorisées (au plus 50). Pour chaque candidat,

il reconstruit la permutation, lit une trame de longueur fixe et tente la vérification GCM, puis Ed25519. Un résultat n'est accepté que si les identifiants signés correspondent *exactement* au candidat ; plusieurs succès ou un indice contradictoire entraînent une abstention. L'interface ne révèle pas les échecs intermédiaires.

4. *LSB matching* : en cas de désaccord, changer la composante de +1 ou -1 selon un tirage aléatoire indépendant ; aux bornes 0 et 255, seule la direction valide est utilisée. La méthode réduit certains artefacts du remplacement LSB mais **ne garantit pas l'indétectabilité statistique**, qui doit être mesurée avec plusieurs tests de stéganalyse sur un corpus séparé des images d'ajustement.
5. Le sceau est inséré dans le PDF sans perte (compression Flate).
6. Extraction : même parcours, lecture des bits, décodage strict de la longueur, déchiffrement avec $K_{enc,d}$ (distincte de $K_{st,d}$), vérification du tag GCM, puis vérification Ed25519 sur une sérialisation canonique des champs. Un échec ne divulgue pas son étape interne à l'appelant. Chaque nouveau chiffrement utilise un nonce GCM aléatoire de 96 bits, contrôlé pour éviter toute réutilisation sous une clé.

A.4 Banc d'évaluation

Les seuils de la famille ES-DIS du recueil sont mesurés par un banc automatisé, versionné sous `tests/marking-bench/` et exécuté en intégration continue à partir de l'itération 4.

— **Corpus** : 5 sujets de 2 à 12 pages (texte dense, texte avec formules, texte avec figures) ; 20 bandeaux ; 100 sceaux.

— **Transformations appliquées aux PDF** : T1 réenregistrement et linéarisation (`qpdf`) ; T2 suppression des métadonnées ; T3 impression virtuelle vers PDF ; T4 extraction d'une page.

— **Attaques appliquées aux bandeaux** : compression JPEG de qualité 70 à 95 ; redimensionnement à 50 % et à 200 % ; bruit gaussien d'écart-type 3 ; conversion PNG, JPEG, PNG.

— **Mesures** : PSNR, SSIM, BER, taux d'identification correcte, nombre de fausses attributions.

— **Résultat** : un fichier CSV par campagne et un verdict par exigence ES-DIS, archivés avec le rapport de l'itération.

— **Test de séparation des copies** : à partir d'un même sujet et de dix destinataires, comparer les cartes des composantes modifiées des sceaux. La permutation doit dépendre du `distributionId` ; les clés HKDF et les flux ChaCha20 doivent différer pour dix identifiants distincts. Cela ne garantit pas la résistance à la collusion.

A.5 Preuve détachée et limites de l'attribution

A.5.1 Pourquoi le manifeste ne signe pas le fichier final

Le manifeste est intégré *dans* l'exemplaire. Insérer dans ce même manifeste le SHA-256 des octets du PDF final créerait une dépendance circulaire. Une signature valide du

manifeste prouve la provenance des champs signés, non l'intégrité de toutes les pages du PDF. L'absence d'une marque n'est pas, en elle-même, la preuve d'une modification : elle peut résulter d'une transformation légitime, d'une perte de synchronisation ou d'une attaque.

A.5.2 Enregistrement détaché signé

Après insertion de toutes les marques et sérialisation définitive du PDF, le serveur calcule $H_f = \text{SHA-256}(PDF_{final})$ et stocke :

- version du schéma, `examId`, `distributionId`, identifiant de clé de signature, H_f, H_o (original), date UTC et statut ;
- la signature Ed25519 par SK_{file} de ces champs dans un encodage binaire canonique versionné (longueurs et ordre immuables, sans ambiguïté de sérialisation) ;
- la référence du reçu de téléchargement signée séparément par SK_{recu}.

L'enregistrement est conservé *hors du PDF* et ses mutations sont contrôlées, journalisées et détectées. À l'investigation, le hash du fichier suspect est d'abord comparé aux enregistrements détachés vérifiés par la clé publique : une correspondance est une preuve d'identité *binaire* avec l'exemplaire émis, pas une preuve de l'identité humaine qui l'a divulgué. Si le PDF a été réenregistré, cette comparaison échoue normalement : on évalue les trois marques *sans prétendre à une intégrité globale.*

A.5.3 Règles de décision : éviter les fausses attributions

Preuve	**Conditions**	**Conclusion permise**
Binaire exacte	SHA-256 du fichier égal à un enregistrement détaché signé valide.	Exemplaire numérique identifié avec preuve cryptographique.
Concordance forte	Manifeste Ed25519 valide, examen cohérent, fingerprint correspondant au *même* destinataire, aucun conflit détecté.	Distribution probable ; origine et limites documentées.
Indice isolé	Manifeste *ou* fingerprint valide, sans second indice indépendant.	Piste non corroborée ; *aucune attribution définitive.*
Conflit / collusion / absence	Signaux divergents, empreinte ambiguë ou contenu non vérifiable.	Indéterminé, alerte d'analyse humaine.

Un *CRC-16* ne constitue ni une signature ni une défense anti-collusion. Un acteur peut reproduire la marque d'une copie qu'il possède. Le système ne peut donc garantir qu'aucun innocent ne sera jamais suspecté ; il minimise le risque de faux positif, s'abstient en présence de discordances et interdit tout usage disciplinaire automatique du rapport.

A.5.4 Journal et frontières de confiance

Une chaîne SHA-256 stockée avec ses propres ancres dans la même base n'est pas résistante à un administrateur de base qui pourrait tout recalculer. L'ancre contient *date*, séquence finale, cardinalité et racine, signés en Ed25519 par SK_{ancre}, et est exportée sur un support append-only hors des privilèges du SGBD. Une vérification à partir du dernier point d'ancrage doit détecter insertion, suppression, réordonnancement et modification des entrées. La suppression réglementaire s'effectue par segments scellés et archives de contrôle conservées selon la politique de rétention.

Annexe B. Modèle de menaces : décomposition

Cette annexe complète le chapitre 7 du recueil : elle contient la décomposition de l'application selon le processus du cours. Les niveaux de confiance (NC), les actifs (A) et les exigences (ES) sont ceux du recueil.

B.1 Informations sur le modèle

Informations sur le modèle de menaces	
Nom de l'application	ExamGuard
Version du modèle	2.0 (baseline conceptuelle du trinôme)
Description	Plateforme de distribution de sujets d'examen. Un enseignant dépose un sujet ; le système en produit un exemplaire individualisé par responsable d'examen, portant un filigrane, une empreinte et un manifeste dissimulé ; un auditeur peut soumettre un fichier divulgué pour retrouver la distribution dont il provient. Quatre rôles : enseignant, responsable d'examen, auditeur, administrateur.
Propriétaire du document	Laith GRITLI, Ahmed ABDELHEDI, Mohamed Yassine AMRI
Participants	Laith GRITLI, Ahmed ABDELHEDI, Mohamed Yassine AMRI
Réviseur	Mohamed-Bécha Kaâniche (encadrant)

B.2 Décomposition : dépendances externes

ID	**Description**
DE-1	L'hôte de services est un serveur Linux durci, à jour de ses correctifs ; WildFly s'y exécute sous un compte non privilégié.
DE-2	WildFly 42 et Java 25 sont maintenus à jour ; l'interface de gestion n'écoute que sur la boucle locale.
DE-3	PostgreSQL 18 s'exécute sur un hôte distinct, durci, non joignable depuis Internet.
DE-4	La connexion entre le serveur d'applications et le SGBD emprunte un réseau privé et est chiffrée.
DE-5	Seul le port 443 est exposé ; les échanges avec les clients se font exclusivement en TLS 1.3.
DE-6	Les navigateurs des utilisateurs sont récents (TLS 1.3, *service workers*, politique de sécurité du contenu).
DE-7	L'horloge des serveurs est synchronisée par NTP.
DE-8	Les bibliothèques tierces (PDFBox, Bouncy Castle, dépendances du client) sont suivies pour leurs vulnérabilités.
DE-9	Le dépôt GitHub et son intégration continue sont accessibles au seul trinôme et à l'encadrant.

B.3 Décomposition : points d'entrée

ID	Nom	Description	Niveaux de confiance
PE-1	Port HTTPS	Unique point d'accès réseau de l'application, en TLS 1.3.	NC-0 à NC-5
PE-1.1	Enveloppe de la PWA	Ressources statiques de l'application et *service worker*.	NC-0 à NC-5
PE-1.2	`/api/auth`	Connexion, second facteur, défi anti-automatisation, déconnexion.	NC-0 à NC-5
PE-1.3	`/api/exams`	Création et consultation des sessions d'examen.	NC-2, NC-3, NC-4
PE-1.4	`/api/exams/{id}/subject`	Dépôt du sujet (envoi de fichier).	NC-3
PE-1.5	`/api/exams/{id}/distributions`	Désignation des destinataires, génération, distribution, révocation.	NC-3
PE-1.6	`/api/copies/{id}/download`	Téléchargement d'un exemplaire.	NC-2
PE-1.7	`/api/investigations`	Dépôt d'un fichier suspect et lecture du rapport.	NC-4
PE-1.8	`/api/audit`, `/api/dashboard`	Consultation du journal, des alertes et des indicateurs.	NC-2 à NC-5 selon la vue
PE-1.9	`/api/admin/users`	Gestion des comptes et des rôles.	NC-5
PE-2	Interface de gestion de WildFly	Port 9990, boucle locale uniquement.	NC-10
PE-3	PostgreSQL	Port 5432, réseau privé uniquement.	NC-7, NC-8, NC-9
PE-4	Système de fichiers de l'hôte	Répertoire de stockage, *credential store*, sauvegardes.	NC-6, NC-10
PE-5	Dépôt GitHub et intégration continue	Code source, configuration, historique.	Équipe

B.4 Décomposition : actifs et niveaux de confiance

Pour chaque actif du chapitre 3 du recueil, le tableau indique les niveaux de confiance qui y accèdent légitimement. Tout autre accès est une menace.

ID	Actif	Niveaux de confiance autorisés
A-1	Sujets originaux	NC-3 (auteur du sujet), NC-6 (chiffré au repos)
A-2	Exemplaires individualisés	NC-2 (destinataire de l'exemplaire), NC-6
A-3	Table des distributions	NC-3 (ses sessions), NC-4 (lecture), NC-7
A-4	Clés cryptographiques	NC-6 uniquement
A-5	Authentifiants et sessions	Titulaire du compte, NC-6, NC-7 (empreintes seulement)
A-6	Journal d'audit	NC-4 et NC-5 (lecture), NC-7 (insertion), NC-8 (lecture)
A-7	Données personnelles	NC-5, la personne concernée, NC-7
A-8	Disponibilité du service	NC-10 (arrêt, redémarrage)
A-9	Valeur probante	NC-4 (production d'un rapport)

B.5 Décomposition : flux de données et frontières de confiance

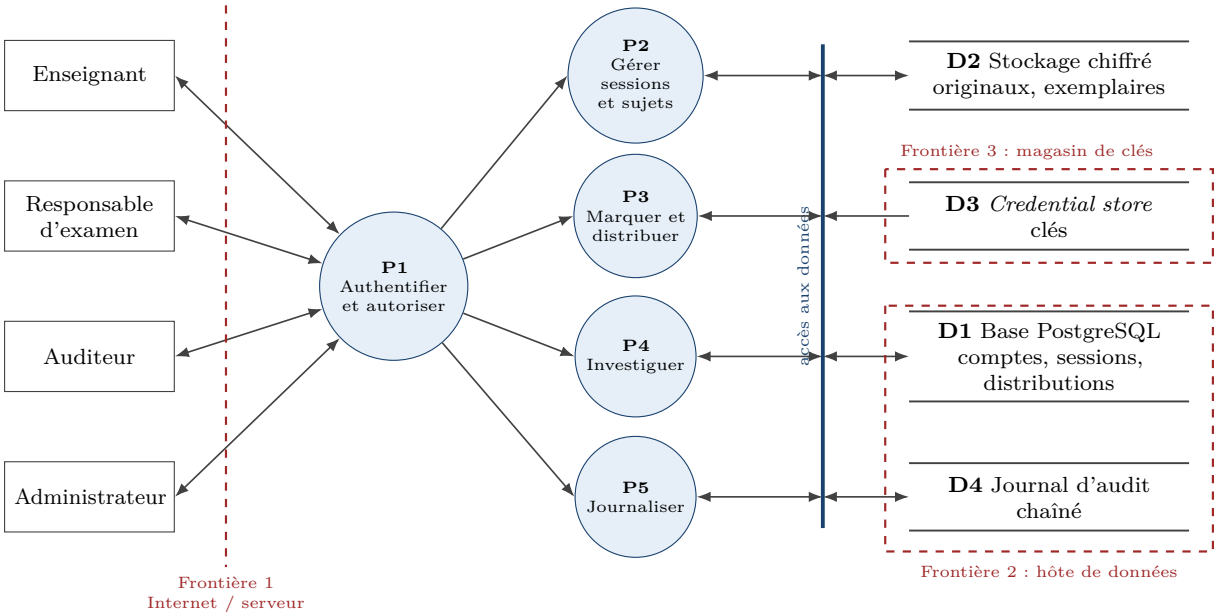


FIGURE B.1 – Flux de données de premier niveau et frontières de confiance

Flux	Trajet	Données	Protection	Frontière
FD-1	Utilisateur → P1	Éléments d'identification, requêtes, fichiers déposés	TLS 1.3, validation	1
FD-2	P1 → utilisateur	Réponses, exemplaire, rapport	TLS 1.3, non stockable	1
FD-3	P1 → D1	Comptes, empreintes de mots de passe, sessions	TLS 1.3, compte NC-7	2
FD-4	P2 → D2	Sujet original	AES-256-GCM	–
FD-5	P2, P3 → D1	Sessions d'examen, distributions, manifestes	Requêtes paramétrées	2
FD-6	D3 → P3, P4	Clés de marquage, de chiffrement et de signature	Lecture par NC-6 seul	3
FD-7	P3 → D2	Exemplaires individualisés	AES-256-GCM	–
FD-8	P4 → D1, D2	Lecture des distributions et des originaux	Rôle auditeur exigé	2
FD-9	P1 à P4 → P5 → D4	Événements d'audit	Chaînage, insertion seule	2
FD-10	D1, D2, D3 → sauvegarde	Copie quotidienne	Chiffrement	hors système

B.6 Profil de sécurité

Catégorie	Réponse d'ExamGuard	Exigences
Validation des entrées	Toute entrée est validée côté serveur par liste d'autorisation ; les fichiers sont contrôlés sur leur contenu réel ; les données lues en base ne sont pas réputées sûres à l'affichage.	ES-VAL-01 à 05, ES-INT-04
Authentification	Mot de passe long haché par Argon2id, second facteur pour les rôles sensibles, verrouillage progressif, transport chiffré exclusif.	ES-AUT-01 à 05
Autorisation	Refus par défaut, contrôle par rôle et par objet à chaque requête, moindre privilège jusque dans les rôles de la base.	ES-AUZ-01 à 05
Gestion de la configuration	Interface de gestion sur la boucle locale, secrets hors dépôt, dépendances analysées.	ES-CFG-02 à 04, ES-CRY-03
Données sensibles	Sujets et exemplaires chiffrés au repos et en transit ; marques pseudonymes ; conservation limitée.	ES-CRY-01, ES-CRY-02, ES-PRV-01 à 03
Gestion de session	Identifiant imprévisible renouvelé à la connexion, cookie inaccessible au script, expiration, jeton anti-CSRF.	ES-SES-01 à 03
Cryptographie	Primitives normalisées uniquement ; clés de 256 bits dans un magasin dédié, une clé par usage, rotation prévue ; aucun algorithme maison.	ES-CRY-02 à 06
Manipulation des paramètres	Identifiants non devinables, champs inconnus rejetés, aucune décision de sécurité fondée sur une donnée du client.	ES-AUZ-02, ES-VAL-01
Gestion des exceptions	Format d'erreur unique sans détail technique ; échec sûr.	ES-ERR-01, ES-ERR-02
Audit et journalisation	Journal chaîné en ajout seul, sans secret, vérifié chaque jour ; règles d'alerte.	ES-JRN-01 à 04

B.7 Grille OWASP Risk Rating reproductible

Cette table fournit les valeurs proposées lors de la revue d'architecture ; elles sont *des hypothèses à discuter*, et non des fréquences expérimentales. L'ordre des huit facteurs L est : compétence, motivation, opportunité, population, découverte, exploitation, connaissance, non-détection. Les quatre facteurs I_t sont : confidentialité, intégrité, disponibilité, imputabilité. Les quatre I_m : impact financier, réputation, conformité, vie privée. Chaque résultat est la moyenne arithmétique de sa liste.

ID	Vraisemblance : huit facteurs	Impact technique : quatre	Impact métier : quatre	L	I_t	I_m
M-01	6, 9, 9, 9, 9, 9, 9, 8	7, 6, 2, 7	3, 7, 5, 5	8.5	5.5	5.0
M-02	6, 8, 7, 6, 7, 7, 9, 8	8, 8, 2, 7	3, 8, 6, 6	7.2	6.2	5.8
M-03	6, 7, 4, 5, 5, 5, 7, 8	7, 5, 2, 5	2, 7, 5, 5	5.9	4.8	4.8
M-04	5, 9, 7, 6, 7, 7, 9, 8	9, 7, 3, 8	5, 9, 7, 7	7.2	6.8	7.0
M-05	6, 9, 7, 6, 7, 7, 9, 8	8, 9, 4, 7	5, 9, 7, 6	7.4	7.0	6.8
M-06	4, 6, 4, 6, 7, 7, 9, 8	6, 3, 1, 5	1, 6, 5, 4	6.4	3.8	4.0
M-07	9, 9, 7, 6, 6, 5, 7, 8	8, 9, 9, 8	7, 9, 7, 6	7.1	8.5	7.2
M-08	6, 9, 7, 6, 7, 7, 9, 8	9, 9, 5, 9	7, 9, 7, 8	7.4	8.0	7.8
M-09	6, 7, 4, 4, 4, 4, 6, 3	6, 9, 2, 8	6, 9, 7, 7	4.8	6.2	7.2
M-10	5, 5, 7, 6, 7, 9, 9, 8	2, 8, 2, 9	2, 7, 6, 5	7.0	5.2	5.0
M-11	6, 6, 4, 2, 3, 5, 5, 1	7, 9, 2, 9	5, 9, 7, 7	4.0	6.8	7.0
M-12	4, 9, 7, 6, 7, 7, 9, 8	4, 9, 2, 9	5, 9, 7, 6	7.1	6.0	6.8
M-13	1, 9, 9, 6, 9, 9, 9, 9	9, 8, 2, 9	7, 9, 7, 6	7.6	7.0	7.2
M-14	6, 9, 7, 6, 7, 5, 7, 8	3, 9, 2, 9	5, 9, 7, 7	6.9	5.8	7.0
M-15	7, 9, 7, 6, 5, 5, 7, 8	5, 9, 2, 9	5, 9, 7, 7	6.8	6.2	7.0
M-16	9, 6, 4, 4, 4, 4, 7, 8	5, 5, 2, 7	3, 7, 5, 5	5.8	4.8	5.0
M-17	6, 9, 4, 4, 5, 5, 7, 3	9, 9, 5, 9	7, 9, 7, 9	5.4	8.0	8.0
M-18	5, 9, 9, 9, 9, 9, 9, 8	2, 5, 9, 7	5, 9, 7, 4	8.4	5.8	6.2

Illustration : M-15 (fausse attribution). L'exposition métier peut être élevée en raison d'un risque de sanction abusive ou de discrédit de l'établissement ; la priorité des contrôles d'abstention est donc maintenue même si la vraisemblance estimée est revue à la baisse. Les évaluations sont révisées avec les résultats d'essais et les retours des utilisateurs.

B.8 Second arbre d'attaque

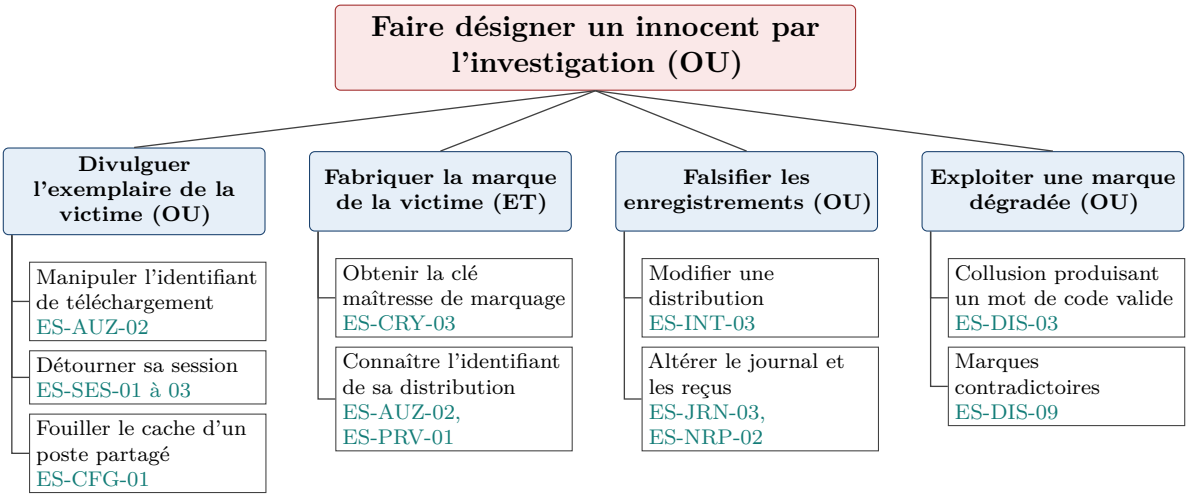


FIGURE B.2 – Arbre d'attaque – faire désigner un innocent par l'investigation

Annexe C. Plan de tests

Les tests TS des exigences de sécurité sont les critères de vérification du chapitre 8 du recueil. Cette annexe détaille les tests fonctionnels (TF) et les tests d'abus de bout en bout (TA).

C.1 Tests fonctionnels

Test	Exigences	Scénario	Résultat attendu
TF-01	F-01	Un enseignant se connecte avec des éléments valides ; un auditeur fait de même avec son code TOTP.	Session ouverte ; chacun arrive sur le tableau de bord de son rôle.
TF-02	F-02, F-03	L'administrateur crée un compte de responsable d'examen.	Compte actif portant un seul rôle ; changement de mot de passe exigé à la première connexion.
TF-03	F-04, F-07	L'enseignant crée une session avec une fenêtre de distribution.	Session visible de son auteur et de l'auditeur ; invisible d'un autre enseignant.
TF-04	F-05, F-06	L'enseignant importe un sujet PDF de 10 pages.	Sujet accepté ; le condensé affiché est égal à celui calculé hors du système.
TF-05	F-12, F-13	L'enseignant désigne 10 destinataires et lance la génération.	10 exemplaires distincts produits en 100 s au plus ; les trois marques de chacun sont relisibles.
TF-06	F-08, F-09	Extraction du manifeste d'un exemplaire.	Les champs du manifeste sont ceux de la distribution ; signature valide.
TF-07	F-10	Détection du filigrane d'un exemplaire.	Identifiant de l'examen correct ; mention visible sur chaque page.
TF-08	F-11	Décodage de l'empreinte de deux exemplaires d'un même sujet.	Deux distributions distinctes, toutes deux correctes.
TF-09	F-14, F-15	L'enseignant valide la distribution ; un responsable télécharge son exemplaire pendant la fenêtre.	Fichier reçu ; reçu signé créé ; compteur de téléchargements à 1 sur 3.
TF-10	F-21	L'enseignant révoque une distribution.	L'exemplaire n'est plus téléchargeable ; la révocation est journalisée.
TF-11	F-16, F-20	L'auditeur soumet un exemplaire intact.	Rapport de niveau « fort » désignant la bonne distribution, avec le résultat des quatre analyses.

Test	Exigences	Scénario	Résultat attendu
TF-12	F-17, F-18, F-19	Après TF-01 à TF-11, l'auditeur filtre le journal par acteur et par action.	Toutes les opérations des tests précédents y figurent ; chaque tableau de bord ne montre que les données permises au rôle.

C.2 Tests d'abus

Chaque cas d'abus du recueil est rejoué contre le système déployé. Le test réussit si l'attaque échoue et laisse une trace.

Test	Cas	Attaque rejouée	Résultat attendu
TA-01	AC-01	1 000 tentatives automatisées contre un compte, à partir d'un dictionnaire contenant le bon mot de passe en dernière position.	Aucune session ouverte ; compte verrouillé ; alerte R1.
TA-02	AC-02	Page tierce émettant une requête modifiante au nom d'un utilisateur connecté ; script tentant de lire le cookie de session.	Requête rejetée (403) ; cookie illisible par le script.
TA-03	AC-03	Le responsable B demande 10 fois l'exemplaire du responsable A ; un enseignant appelle les API d'administration, d'investigation et d'audit ; inspection du cache du navigateur après un téléchargement.	404 à chaque fois et alerte R2 ; 403 pour chaque appel ; aucune donnée d'API ni exemplaire dans le navigateur.
TA-04	AC-04	Dépôt du corpus de 10 fichiers piégés ; balayage actif OWASP ZAP et charges d'injection manuelles sur chaque champ.	Tous les fichiers rejetés ; aucune injection réussie ; erreurs génériques ; aucune fausse entrée de journal.
TA-05	AC-05	Rejeu d'une requête de distribution ; modification du destinataire d'une distribution validée ; contestation d'un téléchargement.	Rejeu et modification rejetés ; le reçu signé établit le téléchargement.
TA-06	AC-06	Suppression d'une entrée du journal par un superutilisateur de la base.	Alerte R4 à la vérification suivante ; entrée manquante localisée.
TA-07	AC-07	(a) Suppression de la modulation des mots ; (b) capture JPEG d'une page sous-capacitaire ; (c) suppression du bandeau.	(a) Indice isolé si seul manifeste valide : pas de conclusion ferme ; (b) examen seulement si filigrane valide ; (c) aucun examId déductible depuis le filigrane absent.
TA-08	AC-08	Sur 100 paires de copies, mélanger les décalages mot à mot et rechercher une cible tierce parmi les HMAC connus.	Mesurer ambiguïtés, faux positifs et abstentions ; aucune désignation ferme sur CRC seul ou marque contradictoire, alerte de collusion.

Test	Cas	Attaque rejouée	Résultat attendu
TA-09	AC-09	Transplanter le sceau de la copie A sur le texte de B, puis modifier une page hors sceau sans toucher à la signature du manifeste.	Tags et signatures du sceau peuvent rester valides, mais signature détachée SHA-256 du PDF échoue ; divergence A/B : pas de désignation ferme.
TA-10	AC-10	Stéganalyse statistique sur 200 sceaux marqués et 200 vierges (jeu indépendant), et 21 requêtes en une heure.	Publier AUC et taux d'erreurs réellement mesurés (sans garantir l'indétectabilité) ; 21e requête rejetée (429).
TA-11	AC-11	Recherche de secrets dans l'historique Git et l'image déployée ; lecture d'une sauvegarde sans clé.	Aucun secret trouvé ; sauvegarde illisible.
TA-12	AC-12	50 connexions et 20 générations simultanées pendant 2 minutes, tandis qu'un utilisateur légitime navigue ; dépôt d'une image de 50 mégapixels.	Au moins 95 % des requêtes légitimes aboutissent ; aucune erreur 5xx ; image rejetée sans décodage complet.

C.3 Essais de falsification et d'interopérabilité additionnels

Ces scénarios complètent TF/TA ; un échec entraîne une issue et une révision mesurée de l'exigence concernée, jamais une falsification des résultats.

— **TI-01 :** sujet de quatre pages à 48 porteurs chacune ; vérifier 192 positions globales et l'absence de réinitialisation du code par page.

— **TI-02 :** retirer une page ou isoler une page sous-capacitaire ; le détecteur doit s'abstenir, même si un CRC accidentellement valide apparaît.

— **TI-03 :** substituer le sceau A dans un PDF B ; confronter HMAC, manifeste Ed25519 et l'enregistrement détaché signé.

— **TI-04 :** modifier un octet hors sceau dans un fichier exact ; le manifeste peut rester valide, mais le SHA-256 final doit diverger.

— **TI-05 :** supprimer/réordonner une entrée de journal en superutilisateur BD, puis vérifier contre une ancre signée conservée hors du SGBD.

— **TI-06 :** charger des PDF à textes tournés, polices complexes, calques et formulaires ; ne pas créer d'exemplaire si la géométrie ne peut être conservée et le texte extrait vérifié.

— **TI-07 :** mesurer les seuils PSNR, SSIM, BER et ROC-AUC sur les jeux de validation indépendants des ajustements d'algorithme.

Annexe D. Fiches des cas d'utilisation de sécurité

Ces fiches détaillent les cas d'utilisation de sécurité de la section 6.4 du recueil selon le gabarit du cours : acteur, description, préconditions, postconditions, déroulement nominal, déroulements alternatifs, exceptions et hypothèses. Elles ne nomment aucun mécanisme architectural. Toutes ont été créées par le trinôme le 12/11/2026.

SUC-01 – Résister aux essais automatisés			
Acteur	Tout utilisateur	**Atténue**	AC-01
Description	Le système vérifie l'identité de l'acteur en rendant les essais en masse coûteux, lents et bornés.		
Préconditions	L'acteur dispose d'un compte actif créé par l'administrateur.		
Postconditions	Une session est ouverte pour l'acteur légitime et pour lui seul ; chaque échec est tracé.		
Déroulement nominal	1. L'acteur présente ses éléments d'identification. 2. Le système les vérifie. 3. Si le rôle l'exige, le système demande une seconde preuve. 4. Le système ouvre la session et trace l'événement.		
Déroulements alternatifs	2a. Après plusieurs échecs consécutifs, le système exige une preuve de travail du client avant tout nouvel essai. 2b. Au-delà d'un seuil, il suspend temporairement le compte et alerte l'administrateur.		
Exceptions	Service de vérification indisponible : le système refuse l'accès (échec sûr).		
Hypothèses	L'acteur protège ses éléments d'identification ; son terminal n'est pas compromis.		
Exigences dérivées	ES-AUT-01 à 05.		

SUC-02 – Protéger la session			
Acteur	Tout utilisateur authentifié	**Atténue**	AC-02
Description	Le système garantit que seul le navigateur qui s'est authentifié peut agir dans la session, et seulement à l'initiative de l'utilisateur.		
Préconditions	Une session vient d'être ouverte par SUC-01.		
Postconditions	Aucune requête émise par un tiers ou par un autre site n'est acceptée dans la session.		
Déroulement nominal	1. Le système attribue à la session un identifiant neuf, imprévisible, inaccessible au code client. 2. Pour chaque requête modifiante, il vérifie une preuve d'origine liée à la session. 3. Il clôt la session à l'expiration ou à la déconnexion.		
Déroulements alternatifs	2a. Preuve d'origine absente ou invalide : la requête est rejetée et tracée.		
Exceptions	Connexion non chiffrée : aucune donnée de session n'est émise.		
Hypothèses	Le navigateur respecte les politiques de sécurité qui lui sont transmises.		
Exigences dérivées	ES-SES-01 à 03, ES-CRY-01, ES-INT-04.		

SUC-03 – Contrôler chaque accès			
Acteur	Tout utilisateur authentifié	**Atténue**	AC-03
Description	À chaque requête, le système vérifie que l'acteur a le droit d'exécuter la fonction demandée et le droit d'accéder à l'objet visé.		
Préconditions	L'acteur est authentifié ; la matrice des droits est définie.		
Postconditions	L'opération n'est exécutée que si les deux vérifications réussissent ; tout refus est tracé.		
Déroulement nominal	1. L'acteur demande une opération sur un objet. 2. Le système vérifie le rôle requis par la fonction. 3. Il vérifie le lien entre l'acteur et l'objet (auteur, destinataire). 4. Il exécute l'opération.		
Déroulements alternatifs	2a. Rôle insuffisant : refus. 3a. Objet d'un tiers : réponse identique à celle d'un objet inexistant. 3b. Téléchargement hors fenêtre ou hors quota : refus.		
Exceptions	Erreur lors de l'évaluation des droits : refus.		
Hypothèses	Les rôles sont attribués correctement par l'administrateur.		
Exigences dérivées	ES-AUZ-01 à 05, ES-ERR-02.		

SUC-04 – Assainir les entrées et les fichiers			
Acteur	Enseignant, auditeur, tout utilisateur	**Atténue**	AC-04
Description	Le système n'utilise une donnée ou un fichier reçu qu'après avoir vérifié qu'il est conforme à ce qui est attendu, et ne révèle rien de son fonctionnement interne en cas de rejet.		
Préconditions	L'acteur est autorisé à soumettre la donnée ou le fichier.		
Postconditions	Seules des données conformes atteignent les traitements et la base ; les fichiers rejetés ne sont pas conservés.		
Déroulement nominal	1. L'acteur soumet une donnée ou un fichier. 2. Le système en contrôle le type réel, la taille, la structure et l'absence de contenu actif. 3. Il le traite dans un espace confiné, avec une durée bornée. 4. Il enregistre le résultat.		
Déroulements alternatifs	2a. Non-conformité : rejet avec un message générique ; l'événement est tracé.		
Exceptions	Dépassement de durée ou de mémoire : le traitement est interrompu et les ressources libérées.		
Hypothèses	Les bibliothèques de traitement sont maintenues à jour.		
Exigences dérivées	ES-VAL-01 à 03, ES-VAL-05, ES-ERR-01, ES-CFG-03.		

SUC-05 – Sceller la distribution			
Acteur	Enseignant, responsable d'examen	**Atténue**	AC-05
Description	Le système fige chaque distribution et conserve une preuve vérifiable de sa création et de chaque téléchargement.		
Préconditions	Le sujet a été importé et son intégrité vérifiée.		
Postconditions	La distribution ne peut plus être modifiée ; son origine et ses téléchargements sont prouvables.		
Déroulement nominal	1. L'enseignant valide la distribution. 2. Le système revérifie l'intégrité de l'original. 3. Il produit et scelle l'enregistrement de distribution. 4. À chaque téléchargement, il produit un reçu scellé.		
Déroulements alternatifs	1a. Correction nécessaire : l'enseignant révoque la distribution et en crée une nouvelle ; les deux opérations sont tracées.		
Exceptions	Original altéré : la génération est bloquée et une alerte est émise. Journal indisponible : l'opération est annulée.		
Hypothèses	L'horloge du serveur est fiable.		
Exigences dérivées	ES-INT-01 à 03, ES-NRP-01, ES-NRP-02.		

SUC-06 – Préserver la piste d'audit			
Acteur	Auditeur, système	**Atténue**	AC-06
Description	Le système enregistre les opérations sensibles de façon que toute modification, suppression ou insertion ultérieure soit détectée, y compris si elle est le fait d'un acteur privilégié.		
Préconditions	Une opération sensible est en cours.		
Postconditions	L'opération est tracée avant d'être confirmée ; l'intégrité de la piste est vérifiable.		
Déroulement nominal	1. Le système compose l'entrée sans y faire figurer de secret. 2. Il la lie à l'entrée précédente. 3. Il confirme l'opération. 4. Périodiquement, il scelle l'état de la piste et en vérifie la continuité.		
Déroulements alternatifs	4a. Rupture de continuité : alerte immédiate à l'administrateur et à l'auditeur, avec localisation de l'entrée en cause.		
Exceptions	Écriture impossible : l'opération métier est refusée.		
Hypothèses	La clé de scellement n'est pas accessible aux administrateurs de la base.		
Exigences dérivées	ES-JRN-01 à 04, ES-AUZ-05.		

SUC-07 – Marquer de façon redondante			
Acteur	Système, pour l'enseignant	**Atténue**	AC-07, AC-08
Description	Le système appose sur chaque exemplaire plusieurs marques indépendantes, imperceptibles, portées par des supports différents, afin qu'une seule manipulation ne les efface pas toutes.		
Préconditions	Le sujet offre une capacité de marquage suffisante.		
Postconditions	Chaque exemplaire est unique, visuellement identique à l'original et rattachable à sa distribution.		
Déroulement nominal	1. Le système calcule les identifiants pseudonymes de l'examen et de la distribution. 2. Il appose la marque d'origine. 3. Il appose la marque individuelle. 4. Il dissimule l'enregistrement de distribution. 5. Il vérifie que les trois marques sont relisibles.		
Déroulements alternatifs	5a. Une marque n'est pas relisible : l'exemplaire est régénéré.		
Exceptions	Capacité insuffisante : la distribution est refusée avec un message explicite.		
Hypothèses	Les destinataires sont informés que les exemplaires sont individualisés.		
Exigences dérivées	ES-DIS-01, 02, 04, 05, ES-VAL-04, ES-PRV-03.		

SUC-08 – Qualifier le résultat d'une investigation			
Acteur	Auditeur	**Atténue**	AC-08, AC-09, AC-10
Description	Le système ne désigne une distribution que si les marques relevées sont valides et concordantes, et accompagne toute conclusion d'un niveau de confiance.		
Préconditions	L'auditeur est authentifié avec une seconde preuve.		
Postconditions	Un rapport gradué est produit ; aucune désignation n'est faite sur la base d'une marque invalide.		
Déroulement nominal	1. L'auditeur soumet un fichier. 2. Le système analyse chaque marque indépendamment. 3. Il confronte les résultats. 4. Il produit le rapport et trace l'analyse.		
Déroulements alternatifs	3a. Marque individuelle invalide : mention « marque altérée », sans désignation. 3b. Marques contradictoires : mention « manipulation possible », sans désignation.		
Exceptions	Quota d'analyses atteint : refus jusqu'à la période suivante.		
Hypothèses	Le rapport est lu par une personne informée qu'il s'agit d'un indice.		
Exigences dérivées	ES-DIS-03, ES-DIS-09, ES-DIS-10, ES-INT-02.		

SUC-09 – Protéger les secrets			
Acteur	Système, administrateur système	**Atténue**	AC-10, AC-11
Description	Le système fait reposer la confidentialité des sujets et la validité des marques sur des secrets qu'il conserve dans un emplacement unique, protégé, et qu'il sait remplacer.		
Préconditions	Les secrets ont été générés aléatoirement à l'installation.		
Postconditions	Aucun secret n'apparaît dans le code, le dépôt, les journaux ou une sauvegarde en clair ; les fichiers stockés et les charges dissimulées sont illisibles sans eux.		
Déroulement nominal	1. Au démarrage, le système lit les secrets dans leur magasin. 2. Il en dérive un secret distinct par usage. 3. Il chiffre tout fichier avant écriture. 4. Il chiffre toute charge avant dissimulation.		
Déroulements alternatifs	1a. Compromission suspectée : l'administrateur déclenche le remplacement des secrets ; les fichiers restent lisibles.		
Exceptions	Magasin illisible : le système ne démarre pas.		
Hypothèses	L'hôte est durci et son accès restreint.		
Exigences dérivées	ES-CRY-02 à 06, ES-DIS-06 à 08, ES-DSP-04.		

SUC-10 – Empêcher la persistance locale			
Acteur	Responsable d'examen	**Atténue**	AC-03
Description	Le système veille à ce qu'aucune donnée confidentielle ne subsiste dans le navigateur après usage, en dehors du fichier que l'utilisateur enregistre lui-même.		
Préconditions	L'utilisateur accède à l'application depuis un navigateur.		
Postconditions	Le stockage du navigateur ne contient que l'enveloppe de l'application.		
Déroulement nominal	1. L'application ne conserve localement que ses ressources statiques. 2. Le système marque chaque réponse confidentielle comme non stockable. 3. Il clôt la session après inactivité.		
Déroulements alternatifs	Hors connexion : l'application affiche un écran d'attente et ne présente aucune donnée.		
Exceptions	Aucune.		
Hypothèses	L'utilisateur est responsable du fichier qu'il enregistre sur son poste.		
Exigences dérivées	ES-CFG-01, ES-SES-02, ES-AUZ-04.		

SUC-11 – Borner les ressources			
Acteur	Système	**Atténue**	AC-12
Description	Le système plafonne le débit des requêtes, la durée et la simultanéité des traitements coûteux, de sorte qu'un acteur ne puisse priver les autres du service.		
Préconditions	Le service est en fonctionnement.		
Postconditions	Les utilisateurs légitimes conservent un temps de réponse acceptable pendant une tentative de saturation.		
Déroulement nominal	1. Le système compte les requêtes par session et par origine. 2. Il met en file les traitements coûteux. 3. Il interrompt tout traitement qui dépasse sa durée maximale.		
Déroulements alternatifs	1a. Seuil dépassé : réponse d'attente indiquant le délai avant nouvel essai.		
Exceptions	File pleine : refus immédiat de la demande.		
Hypothèses	Les attaques volumétriques au niveau du réseau sont traitées par l'hébergement.		
Exigences dérivées	ES-DSP-01 à 03, ES-VAL-03, ES-VAL-05.		

Annexe E. Correspondance avec la version 1.0

Devenir de chaque exigence de sécurité de la version 1.0 du recueil.

v1.0	Énoncé d'origine (résumé)	Défaut	Devenir en v2.0
S-01	Fonctions sensibles après authentification	« Sensibles » non défini	ES-AUT-01
S-02	Hachages robustes, algorithme adapté, sel	Aucun algorithme ni paramètre	ES-AUT-02, ES-AUT-03
S-03	Expiration après une période définie	Durée absente	ES-SES-02
S-04	Attributs de cookie appropriés	« Selon le contexte »	ES-SES-01
S-05	Permissions vérifiées côté serveur	Non testable tel quel	ES-AUZ-01
S-06	Accès aux seules ressources autorisées	Comportement de refus absent	ES-AUZ-02
S-07	Ne pas se fier à l'interface	Redondant avec S-05	ES-AUZ-01, ES-AUZ-03
S-08	Vérifier type, taille, validité des fichiers	Aucune limite chiffrée	ES-VAL-03
S-09	Stockage non accessible publiquement	Chiffrement non exigé	ES-CRY-02, ES-VAL-03
S-10	Conserver le condensé SHA-256	Pas de vérification prévue	ES-INT-01
S-11	Fichiers suspects traités avec précaution	« Conditions limitant les risques »	ES-VAL-05
S-12	Charge chiffrée avant dissimulation	Algorithme absent	ES-DIS-07
S-13	Clés hors du code source	Emplacement non précisé	ES-CRY-03
S-14	Communications protégées par TLS	Version absente	ES-CRY-01
S-15	Pas de cache des documents privés	Non testable tel quel	ES-CFG-01
S-16	Validation côté serveur	Méthode absente	ES-VAL-01
S-17	Requêtes paramétrées	Vérification absente	ES-VAL-02
S-18	Erreurs sans information sensible	Format absent	ES-ERR-01
S-19	Secrets séparés du code	Redondant avec S-13	ES-CRY-03
S-20	Journaliser les opérations sensibles	Liste et champs absents	ES-JRN-01, ES-NRP-01
S-21	Journaux non modifiables par les utilisateurs ordinaires	Ignore les utilisateurs privilégiés	ES-JRN-03, ES-AUZ-05
S-22	Pas de secrets dans les journaux	Vérification absente	ES-JRN-02

v1.0	Énoncé d'origine (résumé)	Défaut	Devenir en v2.0
S-23	Horodatage et contexte	Champs non énumérés	ES-JRN-01, ES-NRP-01
S-24	Limiter taille, durée, ressources	Aucune valeur	ES-DSP-01, ES-DSP-02, ES-VAL-03
S-25	Fonctions essentielles accessibles	Non mesurable	ES-DSP-03
S-26	Un résultat est un indice, non une preuve	Mise en garde, non une exigence	ES-DIS-09
§ 4.8	La non-répudiation n'est pas garantie	Renoncement, non une exigence	ES-NRP-01, ES-NRP-02
Ch. 6	SLI, SLO, RPO, RTO	Contresens sur le sigle SRE	Supprimé ; valeurs reprises par ES-DSP-03 et ES-DSP-04
Ch. 10	Points à préciser	Décisions non prises	Décisions DT-01 à DT-15